



CONFIGURATION MANAGEMENT PLAN

CISA Payroll Department

Johanna Kougbeadjo

CMIT 665 – Cybersecurity Management Policy

Introduction

Configuration Management (CM) is a structured approach aimed at maintaining consistency, thorough documentation, and alignment with organizational and regulatory standards across a system's configuration. This process includes identifying, controlling, tracking, and auditing system components to prevent unauthorized changes, reduce security risks, and sustain operational stability (China & Goodwin, 2024).

The main goal of this Configuration Management Plan (CMP) is to define a systematic method for handling system configurations of the Cybersecurity and Infrastructure Security Agency's (CISA) payroll department. By enforcing strong configuration management controls, CISA seeks to minimize the risk of unauthorized modifications, sustain system stability, and support ongoing compliance with standards like NIST CSF. This CMP applies to all IT assets, cloud environments, and software components within CISA's payroll department's digital ecosystem.

Configuration management at CISA is built upon several fundamental principles and definitions. A Configuration baseline is a formally reviewed and approved specification that acts as a reference for system configurations. The Change Control Board (CCB) is tasked with assessing, approving, and managing changes to system configurations, ensuring that all modifications are documented and comply with security policies. Identification refers to the structured process of defining, labeling, and documenting system components, dependencies, and their configurations to ensure traceability and control (China & Goodwin, 2024).

This CMP is aligned with multiple industry standards relevant to U.S. federal agencies, including NIST SP 800-128 (Guide for Security-Focused Configuration Management), NIST SP 800-53 Rev. 5 (Security and Privacy Controls for Federal Information Systems), and the Federal

Information Security Modernization Act (FISMA). Where applicable, control families from NIST 800-53—such as CM-2 (Baseline Configuration), CM-3 (Configuration Change Control), CM-6 (Configuration Settings), and CM-8 (System Component Inventory)—are reflected in the CMP activities.

CISA also incorporates CIS Controls v8 to enhance baseline security postures, especially around secure configuration for hardware and software. These controls, combined with Infrastructure as Code (IaC) and DevSecOps practices, form the basis of an adaptive, compliance-ready CM framework.

1.0 Configuration Management

Configuration management establishes the foundation for securely managing and controlling CISA's payroll department's technical environments. It ensures consistency across systems, enables secure change management, and supports auditability and regulatory compliance (Netwrix, n.d.; NIST, 2020).

1.1 Teams Involved

Configuration management at CISA's payroll department involves cross-functional collaboration. The Security team enforces security policies and monitors ongoing threats (Majumder, 2025). IT and DevOps teams implement configuration changes using Infrastructure as Code (IaC) and automated pipelines (Configu, 2024). The Compliance team verifies processes against regulatory standards to ensure ongoing audit readiness. The CCB reviews and approves major changes to system configurations, as recommended in federal guidance (NIST, 2011).

1.2 Roles and Responsibilities

Clear roles are essential to maintaining configuration integrity. The Configuration Manager coordinates CM activities and ensures compliance with policies; the CCB governs major changes and ensures technical and security alignment; and engineers implement secure designs and configuration changes. Compliance Auditors validate adherence to policies and regulatory standards, and vendors must comply with CISA's configuration management policies and participate in audits (NIST, 2020).

1.3 CM and the Project Lifecycle

Throughout the system development lifecycle (SDLC), configuration management practices ensure that security, consistency, and recoverability are maintained from design through decommissioning (NIST, 2020). A formal SDLC process is established. It includes requirements gathering, design, implementation, testing, deployment, and maintenance.

1.4 Interfaces with External Organizations

CISA's payroll department collaborates with cloud providers, security vendors, and regulatory auditors to ensure external systems and partnerships align with the organization's configuration standards. Service Level Agreements (SLAs) are used to define deployment timelines, performance expectations, and compliance metrics (Netwrix, n.d.).

2.0 Configuration Management Activities

CISA's CM activities define how configurations are identified, controlled, monitored, and reported, creating a disciplined environment where unauthorized changes are prevented and compliance is maintained (NIST, 2011).

2.1 Configuration Identification

All configuration items (CIs)—applications, infrastructure settings, scripts, and third-party tools—are tracked in version-controlled repositories. Technical specifications such as access controls, encryption methods, and network configurations are documented and managed using best practices recommended by NIST and CIS (Center for Internet Security, 2021; NIST, 2020).

2.2 Configuration Control

Configuration changes at CISA's payroll department follow strict control measures, with every change undergoing a rigorous process of submission, review, testing, and documentation before deployment into production environments. This process begins with formal documentation and analysis of changes for risk and operational impact through submission and impact assessment. Major and critical changes are then evaluated by the Change Control Board (CCB) to ensure technical and security alignment. Before deployment, changes are validated in controlled staging environments to ensure they function as intended. Once approved, updates are reflected in configuration repositories and thoroughly documented in CM systems. Changes are categorized by impact (minor, major, or critical), as recommended by CM-3 in NIST SP 800-53 (NIST, 2020). Tools like GitHub, AWS CloudTrail, Splunk, and IaC scanning platforms are used to automate and secure the change process (Configu, 2024).

2.3 Configuration Status Accounting

Maintaining an accurate, real-time record of system configurations is essential for CISA's payroll department, which achieves this through encrypted cloud storage, automated dashboards, and thorough documentation of release management processes. Encrypted storage protects

configuration data through encryption and access controls, ensuring that sensitive information remains secure. Automated dashboards offer real-time insight into change history and current status. These mechanisms support the controls outlined in CM-8 and CM-6 (NIST, 2020). Additionally, release gatekeeping enforces rigorous reviews before configurations are moved into production environments, ensuring that only verified and compliant changes are implemented. This comprehensive approach ensures that system configurations are consistently tracked, secure, and aligned with organizational standards.

2.4 Configuration Reporting

Ongoing configuration reporting enhances transparency and security posture at CISA's payroll department. Reports summarize changes, identify compliance deviations, and track corrective actions. Quarterly reviews evaluate the effectiveness of CM processes and initiate necessary improvements. This aligns with best practices in continuous improvement and supports organizational readiness for audits (Netwrix, n.d.).

3.0 CM Milestones

Milestones such as baseline establishment, recurring audits, and regulatory compliance checks ensure that the CM process remains measurable, accountable, and aligned with CM-2 and CA-7 controls in NIST SP 800-53 (NIST, 2020).

4.0 Training

Annual training programs educate IT, DevOps, and security staff on configuration management processes, tools, and responsibilities. New employees complete CM onboarding

training within 30 days, reinforcing a culture of compliance and security awareness. This supports the NIST 800-53 AT (Awareness and Training) control family (NIST, 2020).

5.0 Subcontractor/Vendor Support

All third-party providers must comply with CISA's configuration management requirements and participate in security audits. SLAs enforce accountability for configuration integrity and security posture (U.S. Congress, 2014).

6.0 Tools and Systems

To support effective configuration management, CISA's payroll department leverages a suite of tools and systems designed to streamline processes, ensure accountability, and maintain operational stability. CISA uses ITSM platforms such as ServiceNow for change tracking. Change requests are prioritized by urgency and impact. Tools include version control systems, IaC scanning, and monitoring solutions like AWS CloudTrail and Splunk. This supports automated compliance and visibility (Configu, 2024). Change requests are prioritized as minor, standard, major, or emergency, with clear guidelines for handling each category to ensure that resources are allocated appropriately based on urgency and impact. Additionally, a dedicated development environment is used to test new hardware and software before deployment into production, allowing teams to identify and resolve issues in a controlled setting, thereby minimizing risks and ensuring smooth transitions to live systems.

7.0 Security Policy Development

CISA's payroll department develops configuration management policies following a formalized lifecycle based on the NIST Risk Management Framework (RMF). This process begins with preparation and categorization, where the impact level and information types associated with payroll systems are identified. Policy design involves drafting CM policy requirements in consultation with stakeholders, such as the Change Control Board (CCB), security team, IT, and HR compliance. Once drafted, the policies are reviewed by executive sponsors and integrated into operational procedures during the approval and implementation phase. Monitoring and revision are conducted quarterly, with configuration-related incidents and audit results informing policy updates.

Stakeholders involved in this process include the Security & Compliance Team, which handles risk analysis and regulatory interpretation, IT and DevOps for technical feasibility, and the CCB for governance and decision-making. The policy incorporates controls from NIST 800-53 (CM family) and ensures compliance with FISMA and OMB A-130 directives (NIST, 2020). This structured approach ensures that CM policy development is proactive, risk-based, and continuously improved.

References

- Center for Internet Security. (2021). CIS Controls v8.
<https://www.cisecurity.org/controls/cis-controls-list/>
- China, C. R., & Goodwin, M. (2024). What Is Configuration Management? IBM.
<https://www.ibm.com/think/topics/configuration-management>
- Configu. (2024). Configuration Management Software: Infrastructure vs. Applications.
<https://configu.com/blog/configuration-management-software-infrastructure-vs-applications/>
- Majumder, K. (2025). Role of Configuration Management in ISO 27001:2022. LinkedIn.
<https://www.linkedin.com/pulse/role-configuration-management-iso-270012022-kamalika-majumder-ap6gc>
- National Institute of Standards and Technology. (2011). NIST SP 800-128: Guide for Security-Focused Configuration Management of Information Systems.
<https://doi.org/10.6028/NIST.SP.800-128>
- National Institute of Standards and Technology. (2018). Framework for Improving Critical Infrastructure Cybersecurity, Version 1.1.
<https://doi.org/10.6028/NIST.CSWP.04162018>
- National Institute of Standards and Technology. (2020). NIST SP 800-53 Rev. 5: Security and Privacy Controls for Federal Information Systems and Organizations.
<https://doi.org/10.6028/NIST.SP.800-53r5>
- Netwrix. (n.d.). Configuration Compliance Management.
https://www.netwrix.com/configuration_compliance_management.html

- U.S. Congress. (2014). Federal Information Security Modernization Act of 2014, Pub. L. No. 113-283, 128 Stat. 3073. <https://www.congress.gov/bill/113th-congress/house-bill/1163>